CONFIDENCIAL · USO TÉCNICO INTERNO

INFORME OFICIAL DE AUDITORÍA DE SEGURIDAD

Congreso de Educación Técnica Superior 2026 (DETS · GCABA)

Fecha de Emisión: 31 de Octubre de 2026
Metodología: Árbitro Adversarial (Método Gauntlet v2)
Ámbito: Backend Express API, PostgreSQL, Frontend Next.js
Estado: Hallazgos Validados para Remediación

1. Resumen Ejecutivo de la Auditoría

Se completó un escaneo transversal de seguridad sobre la arquitectura completa de la plataforma del Congreso ETS 2026. La evaluación auditó la integridad de autenticación, control de acceso basado en roles (RBAC/BOLA), sanitización de entradas, persistencia de medios, cifrado simétrico y normativas de protección de datos personales (Ley Nacional 25.326). Se identificaron **10 vulnerabilidades** que deben corregirse secuencialmente.

4	3	2	1
CRÍTICAS	ALTAS	MEDIAS	BAJAS

ID	SEVERIDAD	VULNERABILIDAD DETECTADA	COMPONENTE AFECTADO	CWE / CATEGORÍA
SEC-01	CRÍTICA	Mutación de Roles y Catálogos Expuestos sin Autenticación	`backend/routes/admin/catalogos.routes.ts`	CWE-284 / Escalada de Privilegios
SEC-02	CRÍTICA	Cancelación Forzada de Vacantes Confirmadas sin Token/OTP	`backend/routes/usuario.routes.ts`	CWE-639 / BOLA (Inseguridad Lógica)
SEC-03	CRÍTICA	Endpoints Operativos de Acreditación y Feed en Vivo sin Auth	`backend/routes/operator.routes.ts`	CWE-306 / Missing Authentication
SEC-04	CRÍTICA	Emisión Forzada de Certificados y Descarga Masiva de Planillas PDF	`certificados.routes.ts` & `actividades.routes.ts`	CWE-200 / Fuga Masiva de PII
SEC-05	ALTA	Claves Secretas de Firma JWT y Cifrado AES Hardcodeadas	`lib/authService.ts` & `lib/cryptoQR.ts`	CWE-798 / Hardcoded Credentials
SEC-06	ALTA	Fuga de Contraseñas de Correo SMTP en Endpoint General	`routes/admin/configuracion.routes.ts`	CWE-522 / Credenciales Expuestas

ID	SEVERIDAD	VULNERABILIDAD DETECTADA	COMPONENTE AFECTADO	CWE / CATEGORÍA
SEC-07	ALTA	Exposición de Token QR en Intentos Duplicados de Inscripción (409)	`backend/routes/registro.routes.ts`	CWE-200 / Fuga de Credencial QR
SEC-08	MEDIA	Configuración Permisiva de CORS con Credenciales Habilitadas	`backend/src/server.ts`	CWE-942 / CORS Misconfiguration
SEC-09	MEDIA	Subida de Archivos SVG sin Sanitización y Validación MIME Débil	`routes/materiales.routes.ts` & `frontend-cms`	CWE-434 / Stored XSS Potencial
SEC-10	BAJA	Ausencia de Rate Limiting en Login y Consulta de Certificados	`routes/auth.routes.ts` & `certificados.routes.ts`	CWE-307 / Fuerza Bruta

2. Análisis Técnico Detallado de Vulnerabilidades Críticas

SEC-01: Mutación de Roles y Catálogos Expuestos sin Autenticación

`CWE-284 / CWE-269 · CRÍTICA`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/admin/catalogos.routes.ts` (Líneas 11-130)

DESCRIPCIÓN TÉCNICA

El router montado en `/api/admin/catalogos` carece de validación de sesión o jerarquía en sus métodos de mutación. Un actor anónimo puede enviar un `POST /roles` o `PUT /roles/:id` para crear o alterar roles existentes, asignándoles `jerarquia: 5` (Superadmin) y permisos completos en formato JSON. Adicionalmente, el endpoint `GET /` expone los nombres, correos institucionales y números de DNI de todos los disertantes y autoridades registradas.

```
router.post('/roles', async (req: Request, res: Response) => { ... }); // Sin requireHierarchy
router.put('/roles/:id', async (req: Request, res: Response) => { ... }); // Sin requireHierarchy
```

PLAN DE REMEDIACIÓN OBLIGATORIO

Aplicar `requireHierarchy(5)` en todos los endpoints de creación, modificación y eliminación de roles y catálogos, y `requireHierarchy(3)` en la consulta general `GET /`.

SEC-02: Cancelación Forzada de Vacantes Confirmadas sin Token/OTP

`CWE-639 / CWE-862 · CRÍTICA`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/usuario.routes.ts` (Líneas 17-65)

DESCRIPCIÓN TÉCNICA

El endpoint público `POST /api/usuario/cancelar` ejecuta la baja voluntaria e inmediata de un asistente confirmado con solo recibir su `dni_pasaporte` en el cuerpo de la petición. No valida credenciales de sesión, token de firma digital ni código OTP por correo electrónico. Un atacante que conozca o itere números de DNI puede expulsar masivamente a los participantes confirmados del evento y gatillar ascensos no deseados de la lista de espera.

PLAN DE REMEDIACIÓN OBLIGATORIO

Exigir validación de titularidad: o bien requerir el token QR firmado emitido al participante, o implementar un mecanismo de token temporal un solo uso (OTP) despachado al correo registrado del participante para confirmar la baja.

SEC-03: Endpoints Operativos de Acreditación y Feed en Vivo sin Auth

CWE-306 / CWE-287 · CRÍTICA

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/operator.routes.ts` (Líneas 12-160)

DESCRIPCIÓN TÉCNICA

El router completo `/api/operator` se ejecuta sin exigir autenticación ni comprobar jerarquía operativa. Los endpoints `POST /acreditar`, `POST /acreditar-batch` y `POST /walk-in` aceptan un parámetro `operador_id` inyectado directamente en el cuerpo JSON sin contrastarlo con una sesión real. El endpoint `GET /recent` publica en vivo los datos privados (DNI, nombre, foto) de los últimos acreditados, y `GET /config` expone a los operadores del sistema.

PLAN DE REMEDIACIÓN OBLIGATORIO

Proteger todo el módulo con `router.use(requireHierarchy(3))`. Obtener la identidad del operador estrictamente desde el token de sesión (`req.operator.sub`), suprimiendo la aceptación de `operador_id` en el body.

SEC-04: Emisión Forzada de Certificados y Descarga Masiva de Planillas PDF

CWE-200 / CWE-862 · CRÍTICA

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/certificados.routes.ts` (Líneas 408-445) &
`backend/src/routes/actividades.routes.ts` (Líneas 197-215)

DESCRIPCIÓN TÉCNICA

El endpoint `POST /api/certificados` permite a cualquier usuario no autenticado forzar la emisión y registro en base de datos de diplomas con horas cátedra oficiales para cualquier DNI. Simultáneamente, el endpoint `GET /api/actividades/:id/planilla-pdf` genera en PDF la planilla oficial de sala conteniendo la nómina completa de asistentes inscriptos con sus nombres, apellidos, correos y números de documento sin requerir credenciales de operador.

PLAN DE REMEDIACIÓN OBLIGATORIO

Incorporar `requireHierarchy(4)` en la emisión forzada de certificados (`POST /api/certificados`) y `requireHierarchy(3)` en la generación de planillas de asistencia en sala (`GET /:id/planilla-pdf`).

3. Análisis Técnico de Vulnerabilidades de Severidad Alta y Media

SEC-05: Claves Secretas de Firma JWT y Cifrado AES Hardcodeadas como Fallback `CWE-798 / CWE-321 · ALTA`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/lib/authService.ts` (Líneas 17-18) & `backend/src/lib/cryptoQR.ts` (Línea 7)

DESCRIPCIÓN TÉCNICA

Existe una constante estática compartida en el repositorio (`'e4b7c1a89f2d3e4b5a6c7d8e9f0a1b2c3d4e5f6a7b8c9d0e1f2a3b4c5d6e7f8a'`) que se utiliza si `process.env.ENCRYPTION_KEY` no está presente. Si un despliegue omite dicha variable, un tercero puede forjar tokens JWT con rol Superadmin o emitir códigos QR falsificados indetectables para los molinetes.

PLAN DE REMEDIACIÓN OBLIGATORIO

Eliminar el valor de reserva estático. El servidor debe abortar su inicio (`process.exit(1)`) si `ENCRYPTION_KEY` no está provisto en el entorno con exactamente 32 bytes (64 caracteres hexadecimales).

SEC-06: Fuga de Contraseñas de Correo SMTP en Endpoint General de Configuración `CWE-522 · ALTA`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/admin/configuracion.routes.ts` (Líneas 24-35)

DESCRIPCIÓN TÉCNICA

Mientras que el endpoint especializado `GET /api/admin/configuracion/mail` enmascara las claves con viñetas (`••••••••••••`), el endpoint genérico `GET /api/admin/configuracion` efectúa un `SELECT clave, valor FROM configuraciones_sistema` sin exclusiones, devolviendo en texto plano la contraseña de aplicación de Google Workspace almacenada en la clave `cuentas_correo`.

PLAN DE REMEDIACIÓN OBLIGATORIO

Excluir explícitamente del listado general las claves que contengan credenciales o secretos (`cuentas_correo`, `vapid_keys`, tokens) o sanitizar sus valores antes de transmitirlos.

SEC-07: Exposición de Token QR en Intentos Duplicados de Inscripción (409) `CWE-200 · ALTA`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/registro.routes.ts` (Líneas 83-99)

DESCRIPCIÓN TÉCNICA

Al intentar registrar un DNI ya inscripto en la plataforma, la API responde con código HTTP 409 incluyendo en el JSON el `usuario_id` y el `qr_token` del usuario original. Esto permite a cualquier persona obtener la credencial criptográfica de acceso de un asistente simplemente enviando su DNI en el formulario público.

PLAN DE REMEDIACIÓN OBLIGATORIO

Eliminar `qr_token` y `usuario_id` de la respuesta con error 409. El servidor debe retornar únicamente un mensaje notificando que el participante ya se encuentra registrado.

SEC-08: Configuración Permisiva de CORS con Credenciales Habilitadas

CWE-942 · MEDIA

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/server.ts` (Líneas 48-68)

DESCRIPCIÓN TÉCNICA

El verificador de origen de CORS posee una rama condicional `else { callback(null, true); }` combinada con `credentials: true`, lo que permite efectivamente el acceso desde cualquier origen arbitrario. Además, `origin.includes('railway.app')` autoriza peticiones originadas desde cualquier aplicación ajena alojada en Railway.

PLAN DE REMEDIACIÓN OBLIGATORIO

Restringir los orígenes mediante una lista blanca estricta con coincidencia exacta (`whitelist`) y retornar `callback(new Error('CORS origin denied'))` ante cualquier origen no autorizado.

SEC-09: Subida de Archivos SVG sin Sanitización y Validación MIME Débil

CWE-434 / CWE-79 · MEDIA

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/materiales.routes.ts` (Líneas 455-475) & `admin/frontend-cms.routes.ts` (Línea 678)

DESCRIPCIÓN TÉCNICA

Se admite la subida de archivos vectoriales `.svg` servidos estáticamente sin sanitizar su contenido XML. Un vector SVG que contenga código JavaScript embebido (`<script>` o atributos de evento) puede ejecutarse en el navegador del usuario al abrir la imagen en el mismo origen.

PLAN DE REMEDIACIÓN OBLIGATORIO

Sanitizar los archivos SVG antes de persistirlos en disco o forzar cabeceras `Content-Security-Policy: default-src 'none'` y `Content-Disposition: attachment` en los directorios de subidas estáticas.

SEC-10: Ausencia de Rate Limiting en Login y Consulta de Certificados

CWE-307 · BAJA

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/auth.routes.ts` (Línea 9) & `backend/src/routes/certificados.routes.ts` (Línea 184)

DESCRIPCIÓN TÉCNICA

El endpoint `POST /api/admin/auth/login` no implementa limitador de tasa de peticiones (rate limit), facilitando ataques de fuerza bruta contra cuentas de operadores. De igual forma, la consulta pública de diplomas por DNI carece del limitador existente en la consulta de credenciales.

PLAN DE REMEDIACIÓN OBLIGATORIO

Incorporar middleware `rateLimit`: ventana de 15 minutos con máximo 5 intentos fallidos para el endpoint de login y 30 consultas por minuto para certificados.

4. Hoja de Ruta de Remediación Secuencial

Conforme a las directivas del Método Gauntlet v2, las correcciones se implementarán de forma ordenada comenzando por las vulnerabilidades críticas:

1. **Paso 1:** Blindaje de `catalogos.routes.ts` (Protección RBAC nivel 5 en roles y nivel 3 en catálogo).
2. **Paso 2:** Incorporación de verificación OTP / Token en cancelación de usuarios (`usuario.routes.ts`).
3. **Paso 3:** Autenticación obligatoria y extracción de operador en `operator.routes.ts`.
4. **Paso 4:** Protección de emisión de certificados y descarga de planillas de asistencia en sala.
5. **Paso 5:** Erradicación de claves secretas hardcodeadas con fail-safe de inicio.
6. **Paso 6 a 10:** Corrección de fugas en configuración SMTP, DNI 409, reglas CORS, sanitización de SVG y Rate Limiting.
